요약본

2025. 12.

우주 보안모델

Part II. GSaaS 및 공급망

과학기술정보통신부
Ministry of Science and ICT

KISA 한국인터넷진흥원
KOREA INTERNET & SECURITY AGENCY

제1장
개요

제1절 배경

21세기 이후 우주는 단순한 탐사의 대상이 아닌 경제적, 전략적 자산으로 인식되고 있다. 이른바 "뉴스페이스 시대"라 불리는 최근에는 우주산업이 국가 주도에서 민간 중심으로 빠르게 전환되고 있는데, 소형위성, 상업용 발사체, 위성 데이터 서비스의 활성화 등으로 우주 생태계가 다변화되고 있는 상황이다. 즉, 소형위성을 대량으로 생산할 수 있게 되었고 위성을 우주로 보내는 위성 발사 비용이 급격히 감소하였으며 저궤도 위성 서비스의 확산으로 위성 데이터 전송량이 폭증함에 따라 우주 산업이 활기를 띄게 되었다.

이에 따라, 적은 자본으로 지상국 운영의 효율성을 극대화할 수 있는 GSaaS(Ground Station as a Service) 산업이 빠르게 성장하고 있다. GSaaS는 우주기업이 자체 지상국 및 안테나를 가지고 있지 않더라도 인공위성 통신 및 데이터 서비스를 할 수 있도록 공유 인프라를 제공하는 서비스이다. 소형위성을 보유한 스타트업 기업이 GSaaS 서비스를 이용하면, 위성과 통신하는데 필요한 안테나나 지상국 인프라를 빌려 쓰는 형태로 얼마든지 위성 관련 사업을 할 수 있게 되었다. GSaaS의 폭발적 성장으로 통신, 방송, 물류, 금융, 해양, 기상 등 다양한 산업에서 위성 데이터와 서비스 활용도가 높아짐에 따라, 기업 경쟁력과 사용자 신뢰성을 유지하기 위해 우주보안의 필요성이 대두되었다. 우주 인프라에 대한 사이버 공격이나 재밍 등은 단 한 번의 사고로도 막대한 경제적, 사회적 손실을 초래할 수 있기 때문이다.

또한, 우주 산업에 참여하는 공급업체와 파트너가 매우 다양하여 위성 및 지상국 인프라에 대해 다양한 보안 위협이 발생할 수 있다. 즉, 위성 설계/개발, 준비/조립, 발사, 운영, 폐기에 이르는 위성 생애주기 전 과정이 공급망 체계로 구성되어 있으며, 각 단계에서 부품/소프트웨어

위변조, 정보 유출, 사이버 공격 등의 많은 보안 위협이 현실화되고 있는 실정이다. 이는 우주 자산이 고가치로 평가되어 사이버보안 위협 목표가 되기에 충분하기 때문이며 국내 기업의 경쟁력 확보를 위해 우주 공급망 보안도 중요한 요소로 부각되고 있다. 따라서 우주기업은 단위 시스템을 보호하는 수준을 넘어, 위성, 지상국, 사용자 영역의 우주 환경 전반과 우주 공급망 전 단계에서 우주보안 체계를 구축해야 한다.

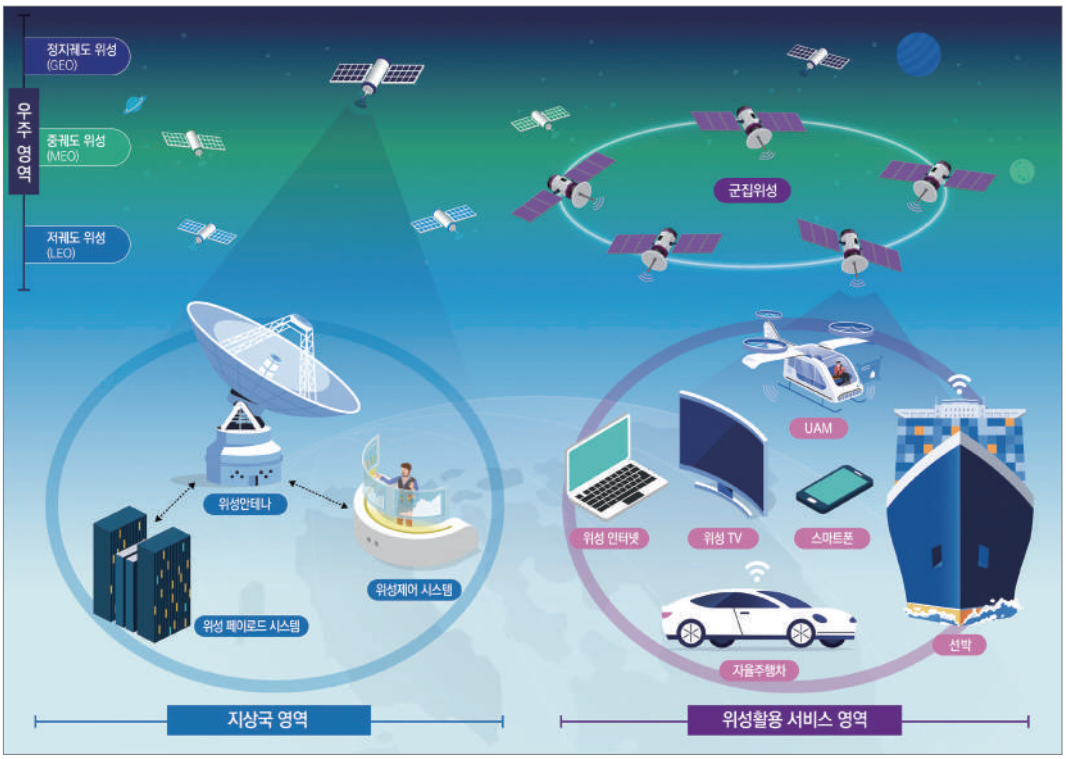
이에, 본 문서는 GSaaS 산업의 폭풍 성장과 다양한 공급망 체계를 고려하여 GSaaS 및 우주 공급망에 대한 보안 위협을 식별하고, 식별된 보안 위협에 대응하기 위한 보안 요구사항, 보안기술, 보안솔루션 등 보안강화 방안을 제시하여, 우주기업 보안담당자가 우주보안 강화 대책 수립시에 참고하고 활용할 수 있도록 지원하는 것을 목적으로 한다.

제2장

우주 아키텍처

우주 아키텍처는 우주 영역, 지상국 영역, 위성 활용 서비스 영역으로 구성된다.

그림 1 우주 아키텍처



우주 아키텍처는 고도 범위에 따라 다양한 위성이 위치한 우주 영역과 위성으로부터 페이로드 데이터(payload data)를 송수신하고, 위성을 제어하기 위한 시스템으로 구성된 지상국 영역, 그리고 위성에 기반한 서비스를 제공하는 위성 활용 서비스 영역으로 구분된다.

■ 우주 영역

우주 영역은 우주 공간에 위치하는 자산으로 구성되며, 대표적인 자산으로 인공위성(이하 '위성'이라 함)이 있다. 위성은 위성의 전반적인 구동을 수행하는 본체와 위성의 임무를 수행하는 탑재체로 구분된다. 본체에는 열제어 시스템, 전력공급 시스템, 위성제어 시스템, 궤도제어 시스템, 위성내부 버스, 명령 및 데이터처리시스템, 통신시스템 등이 있다. 탑재체는 위성 본체에 탑재되어 위성에 부여된 임무를 수행하게 되는데, 탑재체의 임무에 따라 위성의 역할이 결정되며 페이로드, 페이로드 데이터처리시스템 및 통신시스템으로 구성된다.

■ 지상국 영역

지상국은 우주에 있는 위성과 교신하여 위성의 궤도와 상태를 제어하고 데이터를 주고받기 위한 설비이다. 지상국 영역은 위성을 운영 및 제어하기 위한 위성운영 영역과 페이로드에서 데이터를 수신하고 수신한 데이터를 서비스하기 위한 페이로드 데이터 이용 영역으로 구분된다.

위성운영 영역에는 위성상태 모니터링 시스템, 궤도제어시스템, 미션제어 및 운영지원 시스템, 위성제어 시스템, 긴급대응 및 위기관리 시스템 등이 있고, 페이로드 데이터 이용 영역에는 데이터 수신 및 처리 시스템, DB 분석 및 시각화 시스템, 페이로드 데이터 서비스 시스템, 실험계획 및 제어시스템, 관측요청 접수 시스템 등이 있다.

■ 위성 활용 서비스 영역

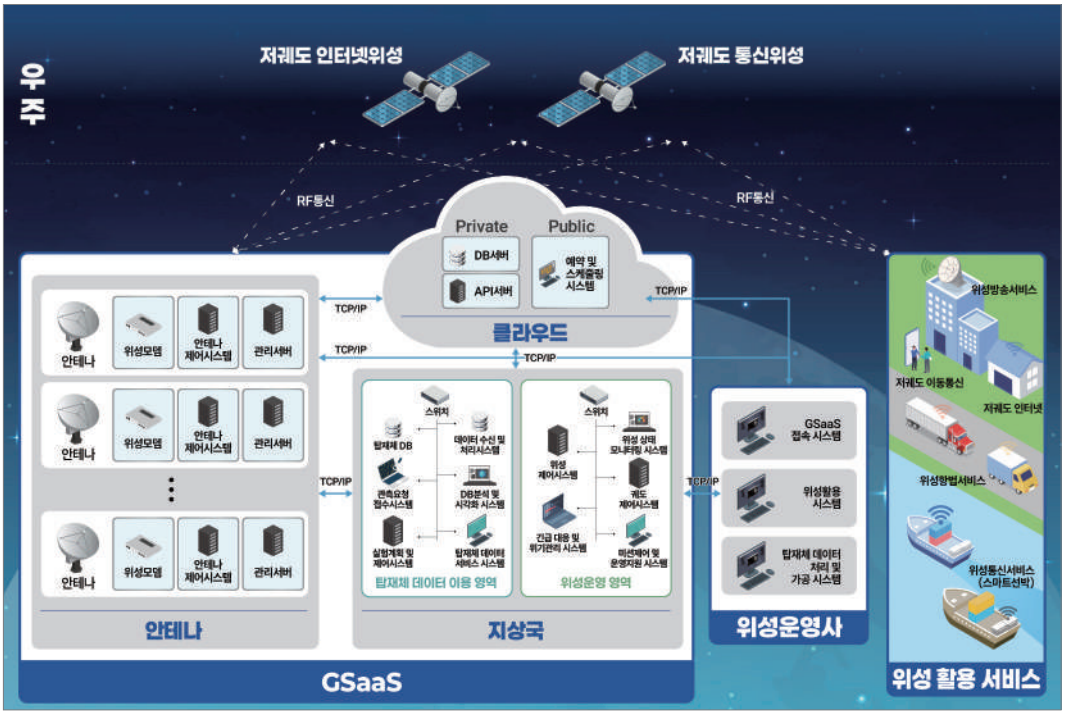
위성 활용 서비스는 위성에서 수집한 데이터와 신호를 지상에서 활용하여 통신, 위치 등 일상과 산업에 적용하는 서비스이다. 위성 활용 서비스에는 위치정보를 제공해 주는 위성항법 서비스와 통신 및 방송을 중계해주는 위성방송통신 서비스로 구분된다. 위성항법서비스는 위성으로부터 위치정보를 수신하여 지상교통 및 항공교통에서의 차량 운행에 사용되는 서비스이고, 위성통신서비스는 위성안테나와 통신위성의 서비스를 활용하여 지상의 인터넷 서비스를 사용할 수 있도록 지원해 주는 서비스이며, 위성방송서비스는 지상 방송국의 방송서비스를 위성을 활용하여 중계하는 방송 서비스이다.

본 보고서에서는 우주보안모델(GSaaS, 우주 공급망)에서 제시한 GSaaS 아키텍처와 우주 공급망 아키텍처를 소개한다.

제1절 GSaaS 아키텍처

GSaaS[1]는 위성과 통신하고 제어하는 지상국 기능을 클라우드를 활용하여 제공하는 서비스로, 위성과 통신하는 안테나 영역과 위성 서비스를 위한 데이터 처리를 수행하는 지상국 영역, 위성 서비스를 제공하는 위성 운영사 영역이 있다.

그림 2 GSaaS 아키텍처



안테나를 통해 위성과 신호를 송수신하며, 지상국은 원활한 통신을 위해 위성의 상태를 모니터링하고 제어한다. 클라우드 환경에서는 데이터의 저장과 서비스 운영을 지원하고, 위성과의 통신을 위한 안테나 예약 기능을 제공한다. 위성 운영사는 GSaaS에 접속하여 수집된 데이터를 분석 및 가공하고, 처리된 데이터를 활용하여 사용자에게 다양한 위성 서비스를 제공한다.

1 GSaaS : Ground Station as a Service

제2절 우주 공급망 아키텍처

위성의 생애 주기(설계/개발, 준비/조립, 발사, 궤도진입 확인, 운영, 위성 해체)를 기반으로 위성/발사체 제조사, 지상국 운영사, 위성 운영사로 구성되어 있다.

그림 3 우주 공급망 아키텍처

위성/발사체 제조사는 탑재체를 포함한 위성 본체와 발사체를 제작하고, 탑재되는 소프트웨어를 개발하는 역할을 수행하며, 위성 운용의 기초가 되는 하드웨어와 소프트웨어 자산을 공급하는 영역이다. 지상국 운영사는 위성과 지상 간 통신을 관리하고, 위성 운용에 필요한 시스템과 소프트웨어를 운용하여, 위성이 임무를 안정적으로 수행할 수 있는 환경을 제공하고 운영을 지원하는 영역이다. 위성 운영사는 위성으로부터 수신한 탑재체 데이터를 목적에 따라 분석 및 처리하고, 이를 활용하여 위성 활용 서비스를 제공하는 영역이다.

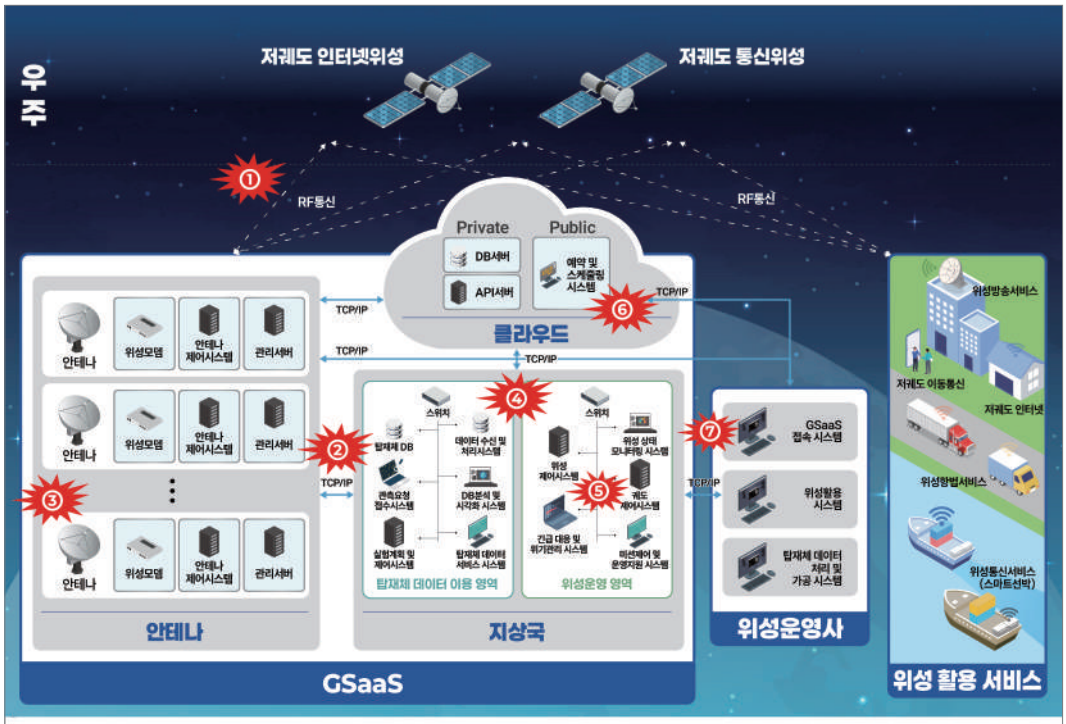
제3장

우주 보안 위협

제1절 GSaaS 보안 위협

GSaaS는 위성, 안테나, 지상국, 클라우드, 위성 운영사 등 다양한 영역이 연결된 구조로 기존의 지상국보다 보안 위협에 노출될 가능성이 높다. GSaaS 아키텍처는 무선 통신 구간과 클라우드 기반의 네트워크 구간이 모두 포함되어 있어 재밍, 스푸핑, 스니핑 등 무선구간에서의 물리적, 기술적 보안 위협과 계정 탈취, 악성코드 감염, 비인가 접근 등 네트워크 구간에서의 사이버 보안 위협이 존재한다.

그림 4 GSaaS 보안 위협



통신 구간	① (위성-안테나 구간) 재밍, RF스니핑/스푸핑 등 공격을 통한 위성 제어 장애 유발 및 탑재체 데이터 탈취 ② (안테나-지상국 구간) 중간자 공격으로 위성으로 전송하는 위성 제어명령을 변조하여 위성 탈취
안테나 영역	③ 협대역 톤을 방출하는 간섭기를 드론에 탑재하여 안테나 보호구역에 침투시켜 무선 주파수 간섭을 통해 위성과 안테나 통신을 교란
지상국·클라우드 영역	④ 스피어 피싱, 악성 이메일을 통한 악성코드 감염 및 전파로 탑재체 등 중요정보 암호화 및 위성 제어 장애 ⑤ 비인가된 내부 임직원이 위성제어시스템에 계정을 탈취하여 위성 제어권 탈취 및 오동작 유발 ⑥ 미흡한 클라우드 IAM 관리로 비인가자가 접근하여 예약 및 스케줄링 데이터 탈취
위성 운영사 영역	⑦ GSaaS 접속시스템 계정 획득 후 예약 및 스케줄링 시스템에 접속하여 예약 데이터 변조

제2절 우주 공급망 보안 위협

우주 공급망 아키텍처는 위성의 설계/개발부터 운영까지의 단계별로 위성/발사체 제조사, 지상국 운영사, 위성 운영사가 연계되어 있다. 설계/개발 단계에서 삽입된 악성코드나 악의적인 백도어는 위성의 임무 수행 및 통신에 직접적인 장애를 초래할 수 있으므로, 위성 본체와 발사체를 포함한 모든 하드웨어, 그리고 운영 및 제어를 위한 시스템과 소프트웨어를 개발 및 납품하는 모든 과정은 위성 임무 수행의 성공과 직결된다.

그림 5 우주 공급망 보안 위협

위성·발사체 제조사	① 위성제어SW에 버스제어를 위한 백도어를 삽입하여 위성이 궤도진입을 확인 후 별도 안테나를 통해 위성체를 제어하여 위성탈취 ② 공격자가 위성제조사 코드DB에 침투하여 로직밤 악성코드를 위성 탑재체SW에 삽입, 위성 궤도진입 후 로직밤 활성화시켜 미션 수행 장애
지상국 운영사	③ 지상국 운영사에서 지상국시스템 개발 시 취약점이 있는 오픈소스를 사용하여 공격자가 원격공격을 통해 권한상승 및 탑재체 데이터 탈취 ④ 공격자가 위성SW업데이트 서버에 침투하여 위성제어SW 업데이트 파일에 악성코드 삽입, 위성에 업데이트 파일 배포 후 위성 제어 장애 발생 ⑤ 지상국 운영사 SW개발 환경(IDE, CI/CD)에 빌드 시 악성코드를 생성하는 변조된 플러그인이 설치되어 위성제어SW빌드 및 배포 시 위성이 악성코드에 감염, 위성 제어 장애 유발
위성 운영사	⑥ 위성 운영사 직원이 재택근무 환경에서 스피어피싱을 통해 악성코드에 감염되어 소스코드 유출

제3절 우주 보안 위협 시나리오

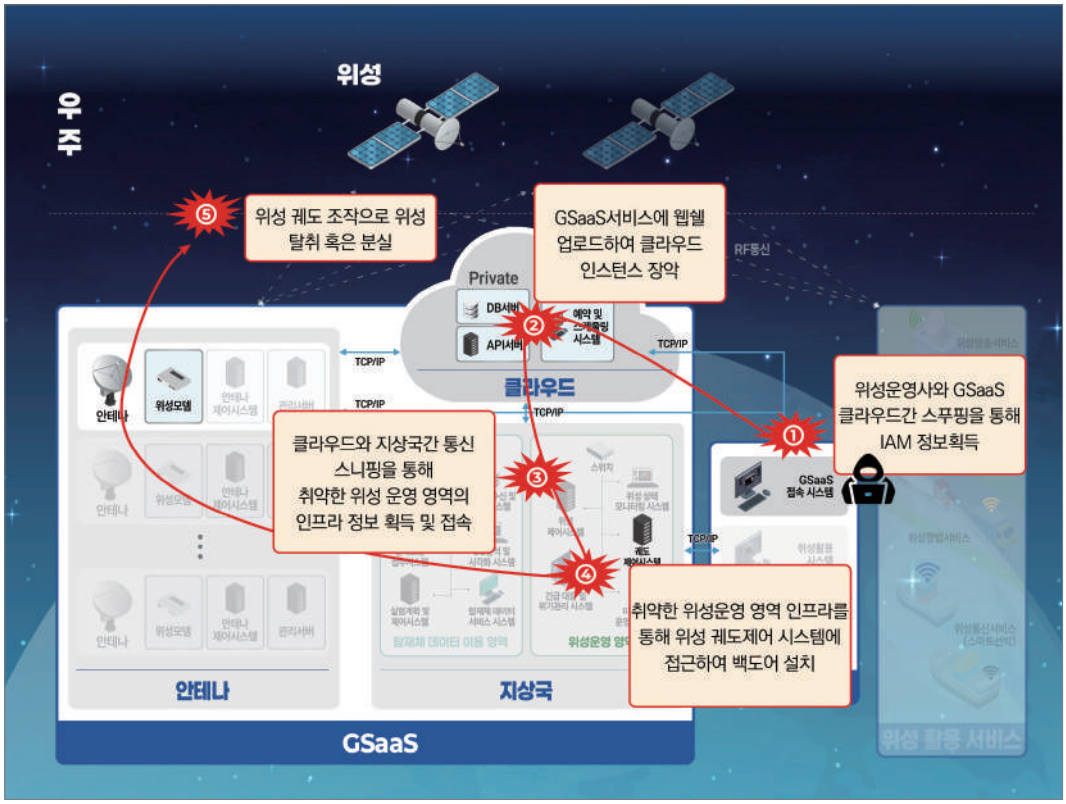
최근 우주 관련 기업에서 발생한 보안 사고 및 사회적으로 크게 이슈화된 보안사고 사례를 검토하여, GSaaS 및 우주 공급망 환경에서 발생할 수 있는 6가지 보안 위협 시나리오를 도출하였다.

1. GSaaS 보안 위협 시나리오

GSaaS 보안 위협 시나리오는 위성 제어권 탈취, 데이터 변조, 위성 통신 마비의 3가지 시나리오를 도출하였으며 세부 시나리오는 다음과 같다.

시나리오1 취약한 인증관리 및 접근제어를 이용한 위성체 제어권 탈취

그림 6 취약한 인증관리 및 접근제어를 이용한 위성체 제어권 탈취 시나리오



① 지상국에서 제공하는 클라우드에 구축된 GSaaS 서비스가 평문 통신을 하는 경우 공격자는 스니핑을 통해 GSaaS 클라우드 IAM정보를 탈취할 수 있다. 공격자는 탈취한 IAM정보를 이용해 위성 운영사로 가장하여 GSaaS 클라우드에 접속할 수 있다.

② GSaaS 클라우드의 웹서버에 파일 업로드 취약점이 존재할 경우 공격자는 위성 운영사의 권한으로 웹서버에 웹쉘을 업로드할 수 있다. 서버의 미흡한 권한 관리와 경로 조작 취약점을 이용해 관리자 권한을 탈취하여 해당 클라우드 인스턴스를 장악한다.

③ 공격자는 장악한 GSaaS 클라우드 인스턴스를 이용하여 클라우드 영역과 지상국 위성운영 간의 통신 패킷을 수집 및 분석하여 평문통신 구간을 수집하다. 평문 통신 패킷 수집 및 분석을 통해 지상국 위성 운영 영역 서버의 접속 정보 및 권한을 탈취하고 해당 취약 서버에 백도어를 설치하여 위성운영 네트워크에 접속한다.

④ 백도어를 통해 접속한 취약한 서버를 통해 위성운영 영역 네트워크의 통신 패킷을 수집 및 분석하여 위성궤도 제어시스템의 접속 정보 및 권한을 탈취한다. 탈취한 접속 정보와 권한을 이용해 위성궤도 제어시스템에 접속하고 백도어를 설치한다.

⑤ 공격자는 장악한 위성궤도 제어시스템에서 타겟 위성 접속 정보를 수집하고 정당한 명령으로 가장하여 궤도 수정 명령을 하달한다. 공격자의 위성 궤도 조작으로 위성이 궤도를 이탈하여 분실되거나 수집한 위성 접속정보를 이용해 위성을 탈취한다.

시나리오2 비인가 장비 및 백도어를 이용해 지상국 침투 후 위성통신 데이터 변조

그림 7 비인가 장비 및 백도어를 이용해 지상국 침투 후 위성통신 데이터 변조 시나리오

① 지상국 내부 시스템 유지보수 시 매체 제어가 미흡하거나 이동형 저장장치에 대한 별도 통제가 부재한 취약한 환경에서 운영될 수 있다. 위성운영 영역 담당 엔지니어가 유지보수에 사용하는 이동형 저장장치에 백도어를 배포하는 악성코드에 감염된 사실을 인지하지 못하고 위성 제어시스템 서버에 접속 시 시스템에 백도어형 악성코드가 설치될 수 있다. 혹은 내부 네트워크에 네트워크 접근제어 부재 시 악의적인 내부 임직원이 쉽게 눈에 띄지 않는 싱글보드 컴퓨터(라즈베리파이, 라떼판다 등)에 백도어를 설치하고 위성운영 영역 네트워크에 연결할 수도 있다.

② 지상국 내부의 위성운영 영역 네트워크에 인터넷 접점이 존재하거나 악의적인 임직원이 방화벽 정책의 수정이 가능한 경우 공격자가 외부에서 내부에 설치된 백도어형 악성코드를 이용해 내부 네트워크에 접속할 수 있다.

③ 지상국 내부 네트워크에 이상징후 탐지 및 차단 솔루션이 부재한 경우 공격자는 네트워크 스캔 등을 사용해 취약한 시스템 정보를 수집할수 있다. 공격자는 수집한 내부 시스템 정보를 이용해 권한상승이 가능하고, 위성 제어시스템 등 중요 자산에 관리자 권한으로 접속할 수 있는 취약한 자산을 타겟으로 공격을 시도할 수 있다. 공격자가 위성 제어시스템의 관리자 권한을 획득 한 경우 위성 접속 정보 등 중요 정보를 수집할 수 있다.

④ 공격자는 수집한 위성 접속 정보를 이용하여 타겟 위성에 접속하여 해당 위성에서 전송되는 데이터를 변조하는 악성코드를 삽입할 수 있다.

⑤ 공격자가 설치한 악성코드로 인해 위성에 전송되는 데이터가 변조되고 이로 인해 위성 활용 서비스에서 통신장애가 발생할 수 있다.

시나리오3 드론을 활용한 물리적 공격으로 위성 통신 마비

그림 8 드론을 활용한 물리적 공격으로 위성 통신 마비 시나리오

① 지상국에서 제공하는 클라우드에 구축된 GSaaS 서비스가 평문통신을 하는 경우 공격자는 스니핑을 통해 데이터를 수집하고 분석하여 타겟 위성이 사용하는 안테나의 위치 정보를 확인한다.

② 확인된 안테나를 재밍 장비 혹은 폭발물을 탑재한 드론을 이용하여 재밍 공격 혹은 물리적으로 파괴한다.

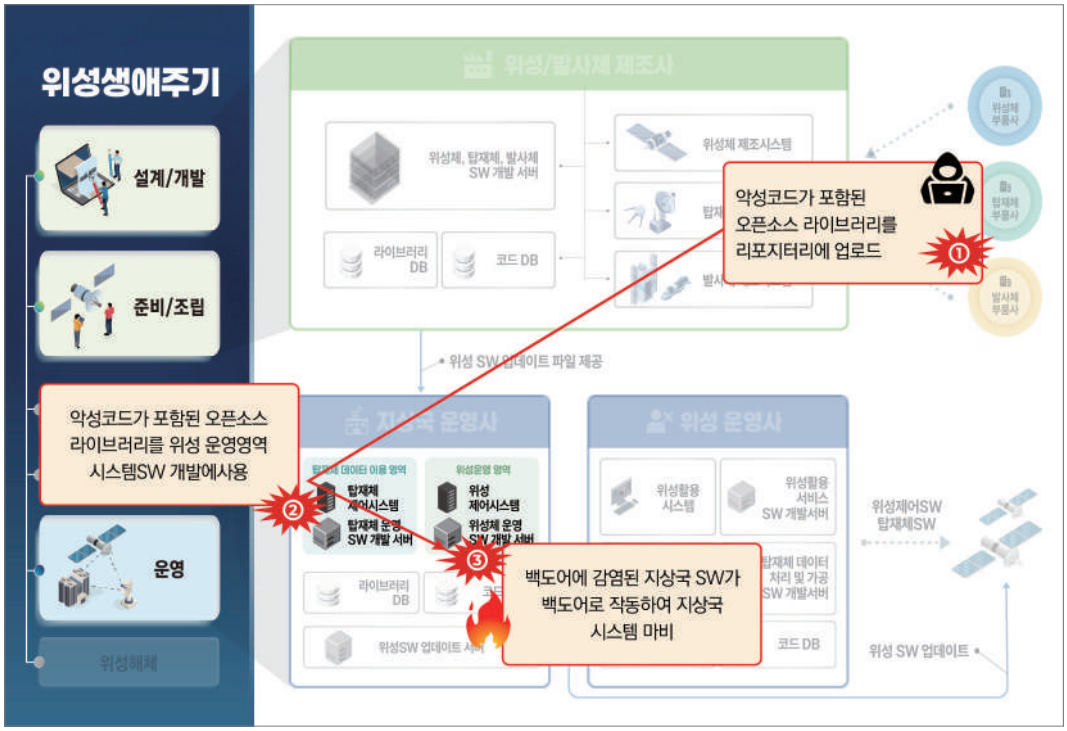
③ 공격자의 안테나 재밍 공격 혹은 물리적 파괴로 인해 안테나와 위성 간 통신이 마비된다.

2. 우주 공급망 보안 위협 시나리오

우주 공급망 보안 위협 시나리오는 지상국 시스템 마비, 위성 탑재체 오동작 유발, 위성체 오동작 유발의 3가지 시나리오를 도출하였으며 세부 시나리오는 다음과 같다.

시나리오1 취약한 오픈소스 사용으로 지상국 시스템 마비

그림 9 취약한 오픈소스 사용으로 지상국 시스템 마비 시나리오



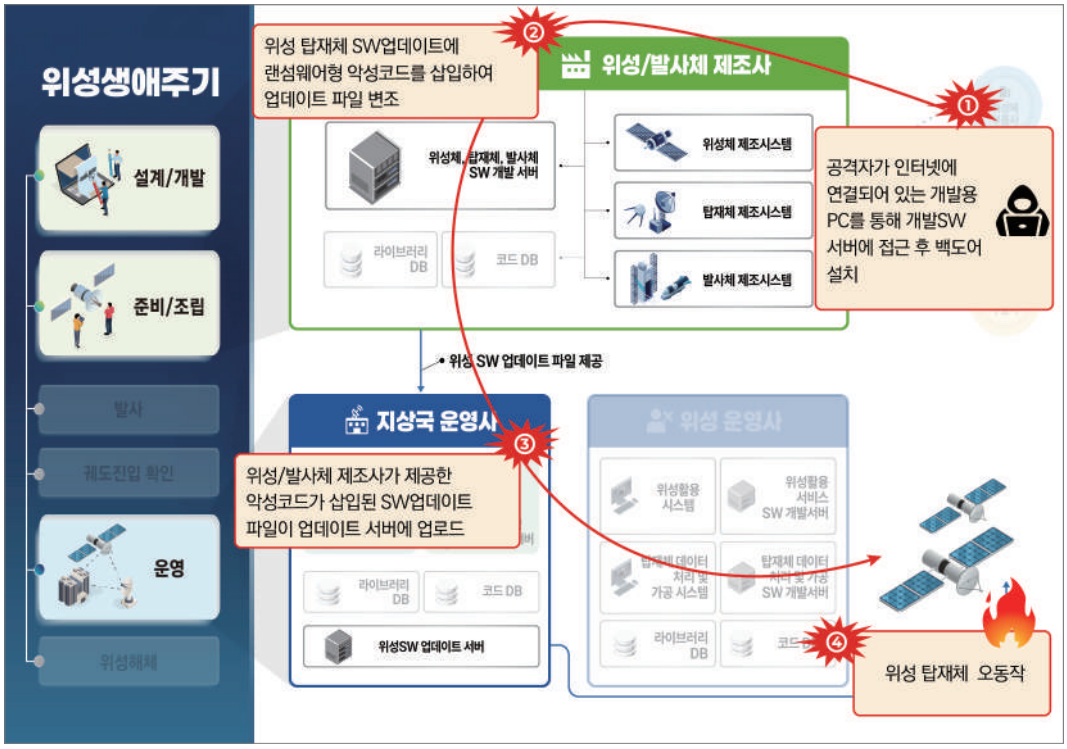
① 공격자는 지상국 운영사가 서비스 개발 시 통상적으로 사용하는 오픈소스 라이브러리 정보를 수집한다. 공격자가 해당 오픈소스 라이브러리 개발 커뮤니티에 가입하여 백도어 형 악성코드를 삽입하고 리포지터리에 최신 버전으로 등록한다.

② 지상국 운영사는 별도의 라이브러리 검증 절차 없이 악성코드가 삽입된 취약한 오픈소스 라이브러리를 포함하여 서비스를 개발하고 배포한다.

③ 공격자는 백도어를 통해 지상국 운영사의 시스템에 접속하고 추가로 취약한 시스템 정보를 수집하여 지상국 서비스를 장악한 후 지상국 시스템을 마비시킨다.

시나리오2 위성 탑재체 업데이트 파일에 악성코드 삽입으로 위성 탑재체 오동작 유발

그림 10 탑재체 업데이트 파일에 악성코드 삽입으로 위성 오동작 유발



① 공격자는 인터넷 등 공개된 네트워크에 연결된 개발용 PC에 피싱 메일 등 사회 공학을 통해 접근한다. 개발자 PC에 연결된 위성체, 탑재체, 발사체 SW 개발(업데이트) 서버에 접근하여 백도어를 설치한다.

② 공격자는 위성 탑재체 SW 업데이트에 랜섬웨어형 악성코드를 삽입하여 업데이트 파일을 변조한다.

③ 위성/발사체 제조사가 악성코드가 삽입된 SW 업데이트 파일을 지상국 운영사에 제공한다. 지상국 운영사는 악성코드가 삽입된 SW 업데이트 파일을 별도의 검증 없이 위성 SW 업데이트 서버에 업로드 한다.

④ SW 업데이트를 통해 설치된 악성코드로 인해 암호화 등 위성 탑재체 오동작을 유발한다.

시나리오3 변조된 개발환경 플러그인 사용으로 위성체 오동작 유발

그림 11 변조된 개발환경 플러그인 사용으로 위성체 오동작 유발

① 공격자가 SW개발 IDE 및 CI/CD의 유명 플러그인 개발 커뮤니티에 가입하여 빌드 시 백도어를 생성하는 등 SW를 변조하는 악성코드가 삽입된 플러그인을 저장소에 업로드한다.

② 위성체 부품 FW개발자가 자신의 IDE 등 개발 및 빌드 환경 구축 중 플러그인 설치에 대한 별도 검증 절차 부재로 해당 악성코드가 삽입된 IDE 및 CI/CD를 사용해 FW를 개발하고 부품에 탑재하여 납품한다.

③ 위성체 제조사가 부품에 탑재된 FW에 대한 별도의 검증 단계를 거치지 않고 악성코드가 탑재된 취약한 부품을 사용하여 위성체를 제조하여 위성 운영사에 납품한다.

④ 공격자는 백도어를 사용해 감염된 위성체의 오동작을 유발한다.

제4장

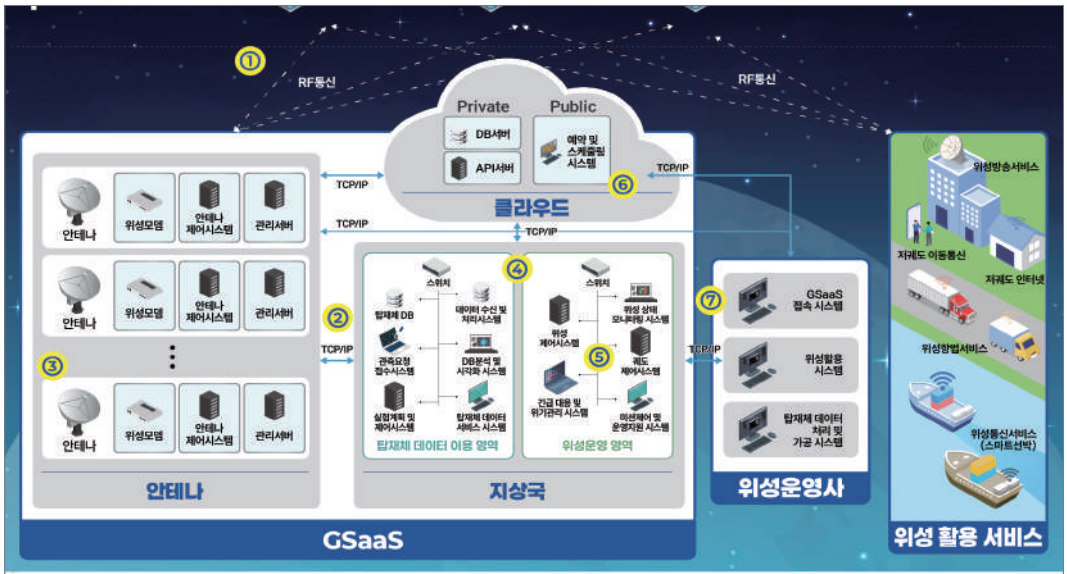
우주 보안 아키텍처

제1절 우주 보안 요구사항

1. GsaaS 보안 요구사항

GSaaS 통신 구간에서의 전파 교란이나 시스템 접근 권한을 탈취하여 위성 제어권을 침해하는 행위, 악성코드 감염이나 미흡한 보안 설정으로 인한 중요정보 유출 및 데이터 변조 등 다양한 보안 위협에 대응하기 위한 GSaaS의 주요 보안 요구사항으로는 안티 재밍 대책 마련, 운영 시스템 관리자 및 사용자 인증 강화, 권한 관리, 클라우드 인프라 및 사용자 보안 강화 등이 있다.

그림 12 GSaaS 주요 보안 요구사항

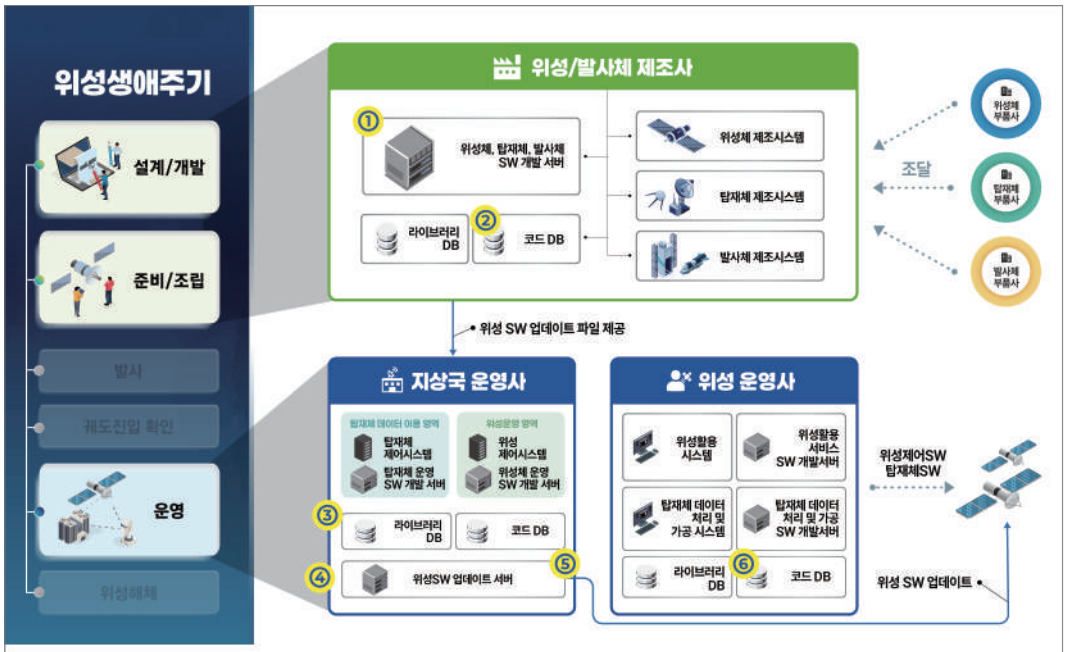


통신 구간	① 위성 통신 방해 전파에 대해 안테나 이중화 등 안티 재밍 대책 마련 ② 안테나와 지상국 구간의 가상사설망 등 안전한 통신 방안 마련
안테나	③ 드론을 사용한 지상국 및 안테나 위협 드론재머 등 대응책 마련
지상국·클라우드	④ 위성 운영 네트워크 자산은 승인된 SW만 설치 허용 ⑤ 멀티팩터 인증 등 위성 운영 시스템 관리자 및 사용자 인증 강화 및 권한 관리 ⑥ CASB, CSPM 도입 등 위성 서비스 클라우드 인프라 및 사용자 보안 강화
위성 운영사	⑦ 위성 서비스 클라우드 인프라 및 사용자 보안 강화

1. 우주 공급망 보안 요구사항

우주 공급망에서는 소프트웨어를 개발하는 과정에서 백도어가 삽입되어 위성의 미션 수행에 장애가 발생하거나 취약한 오픈소스 라이브러리를 통한 원격 공격으로 탑재체 데이터 탈취, 악성코드가 삽입된 업데이트 파일로 인해 위성 제어 장애를 유발, 재택 및 원격 근무 시 데이터가 유출되는 등의 보안 위협이 존재한다. 이러한 보안 위협에 대응하기 위한 우주 공급망의 주요 보안 요구사항은 소프트웨어 및 펌웨어 배포 전 충분한 검증 절차 수행, 악성코드 검사, 소프트웨어 개발 시 검증된 도구 사용, 원격 근무 솔루션 도입 등이 있다.

그림 13 우주 공급망 주요 보안 요구사항



위성·발사체 제조사	① 위성에 탑재되는 SW, FW는 배포 전 테스트 절차에 따라 충분한 검증 후 배포 ② 위성SW 개발 환경 구축 시 코드 저장소는 암호화, 접근 제어 등 적절한 보안 조치 적용
지상국 운영사	③ 위성 운영영역 시스템SW 개발 시 검증된 오픈소스 라이브러리만 사용 ④ 위성 SW 및 SW 업데이트 파일은 배포 전 무결성 검증을 통해 변조 여부 확인 ⑤ 위성 운영영역 시스템SW 개발 환경 구축 시 IDE, CI/CD 등 충분히 검증된 개발 및 배포 도구만 사용
위성 운영사	⑥ 비대면 업무 환경에서 위성 SW 개발시 원격 근무 솔루션 도입 등 충분한 보안 대책 마련

제2절 우주 보안 아키텍처

우주 보안 아키텍처는 GSaaS와 우주 공급망에서 도출된 보안 요구사항을 바탕으로 보안기술, 보안솔루션에 대한 활용방안을 도식화하여 표현한 아키텍처이다.

1. GsaaS 보안 아키텍처

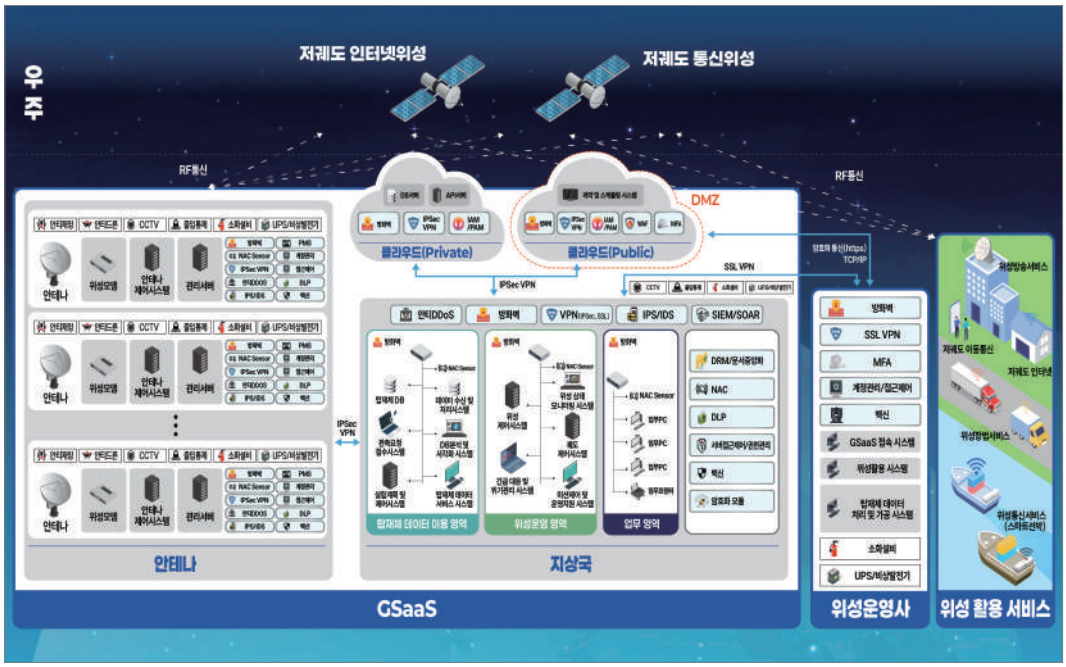
GSaaS 보안 아키텍처 구성 기준은 앞서 살펴본 보안 요구사항을 반영하여 아래와 같은 기준으로 구성한다.

그림 14 GSaaS 보안 아키텍처 구성기준

네트워크 접근제어	◆ **네트워크를 물리적/논리적으로 분리** - 방화벽 및 스위치 장비를 사용하여 물리적/논리적 네트워크 분리(안테나 영역, 탑재체 데이터 이용 영역, 위성운영 영역, 클라우드 영역 등) ◆ **방화벽에서 네트워크별 접근에 대한 IP/Port 접근 허용 정책 설정**
텔리거밴드, 페이로드 데이터 보호	◆ **통신구간 간 전송 중인 데이터 도청 및 변조 차단** - 안테나, 지상국, 프라이빗 클라우드 간 IPSec VPN 시스템 구축 - 위성 운영사와 지상국 간 SSL VPN 시스템 구축 - 지상국에서 퍼블릭 클라우드를 통해 위성 운영사에 제공하는 웹 서비스는 https 적용
인증 및 권한제어	◆ **안테나 시스템, 지상국 시스템, 클라우드 시스템 등에 디폴트 계정 및 취약한 계정에 의한 비인가자의 접근제 및 차단** - 지상국 및 안테나 영역 서버 접근통제 및 권한관리 시스템 구축 - 클라우드 서비스는 IAM/PAM을 사용하여 접근통제 및 권한관리 시스템 구축
침입탐지/악성코드 차단	◆ **다양한 악성코드 및 외부의 침해 행위로부터 지상국 내부 네트워크 및 시스템 보호** - 원격접속 및 악성코드 패턴 등의 이상징후 탐지 및 차단을 위한 침입방지시스템(IPS) 구축 - 악성코드 탐지 및 치료, 제거를 위한 백신 시스템 및 엔드포인트 보안 솔루션 구축
물리적 접근제어	◆ **지상국, 안테나등으로 비인가자의 물리적 접근 차단** - CCTV, 출입통제 시스템 구축 - 안티 재밍 시스템, 안티 드론 시스템 구축

다음은 GSaaS 보안 아키텍처 구성 기준을 적용한 GSaaS 보안 아키텍처이다.

그림 15 GSaaS 보안 아키텍처



2. 우주 공급망 보안 아키텍처

우주 공급망 보안 아키텍처 구성 기준은 앞서 살펴본 보안 요구사항을 반영하여 아래와 같은 기준으로 구성한다.

그림 16 우주 공급망 보안 아키텍처 구성기준

안전한 오픈소스 라이브러리 사용

- **위성SW 개발 단계별 및 SW 납품 단계별 SBOM 검증을 통해 안전한 오픈소스 라이브러리 사용 여부 확인**
  - SBOM 검증 도구 도입 및 운영
- **위성SW 개발시 안전한 라이브러리 사용 및 개발환경 통일을 위해 라이브러리 저장소 구축 및 운영**
  - 방화벽에서 위성SW개발과 관련된 특정 IP/Port만 라이브러리 저장소 서버 접속 허용

시큐어 코딩 및 소스코드 보호

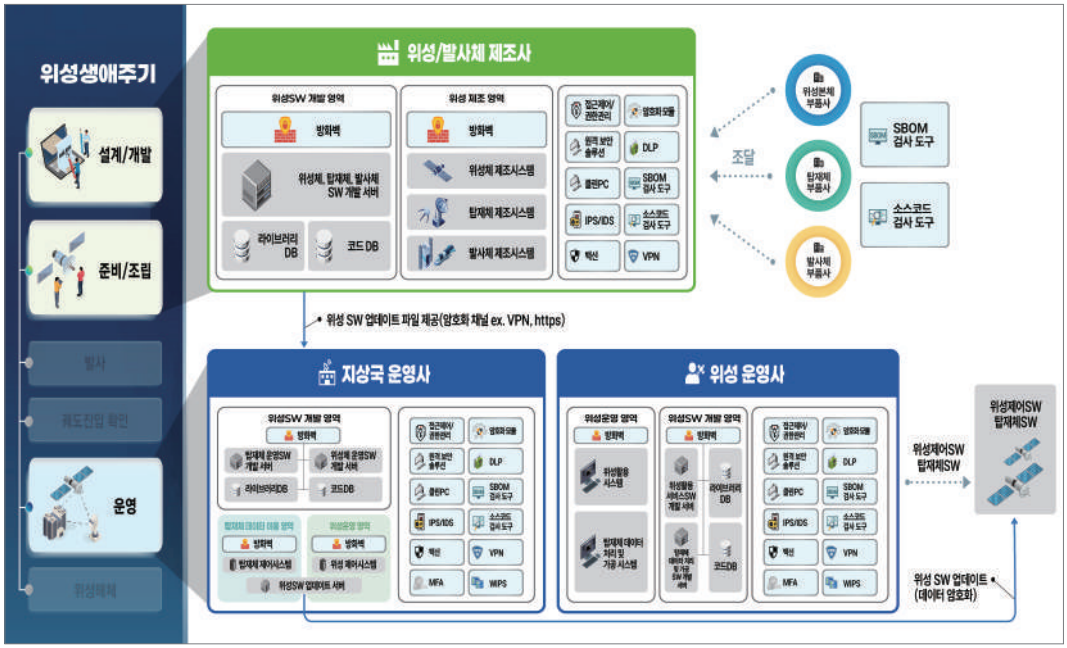
- **위성SW 개발 및 테스트 전 단계에서 SW보안취약점 제거**
  - 정적/동적 소스코드 분석도구 도입 및 운영
- **안전한 소스코드 저장소 구축 및 운영**
  - 방화벽에서 위성SW개발과 관련된 특정 IP/Port만 소스코드 저장소 서버 접속 허용

안전한 개발환경 구축

- **위성SW 개발 영역을 위성 제조 및 위성운영 영역과 물리적/논리적으로 네트워크 분리**
- **위성SW 개발, 테스트, 빌드, 배포 서버의 데이터에 대한 비인가 변조/삭제/유출 차단**
  - 서버 접근제어 솔루션 구축, 매체제어 솔루션 구축, IPS/IDS 구축
- **위성SW 개발 단말 보안 환경 구축**
  - 백신 도입, 엔드포인트 보안 솔루션 도입
- **비대면 업무 개발 단말 보안 환경 구축**
  - 비대면 업무 보안 솔루션 구축, 엔드포인트 보안 솔루션 도입, VPN 등 암호화 채널 구축

다음은 우주 공급망 보안 아키텍처 구성 기준을 적용한 우주 공급망 보안 아키텍처이다.

그림 17 우주 공급망 보안 아키텍처



제3절 우주 보안 체크리스트

우주기업 보안담당자가 우주기업의 현재 보안상황을 진단하고 우주보안 대책을 수립할 수 있도록 우주보안 체크리스트를 제시한다. 우주 보안 체크리스트는 CMMC[2] 2단계 통제항목을 기준으로 한국형 위험관리체계인 K-RMF[3], 유럽연합 보안 Directive인 NIS2[4], 국내 정보보호 관리체계(ISMS[5]) 를 반영하여 작성하였다. 우주 보안 체크리스트는 12개 분야, 53개 항목으로 구성된다.

표 26 우주 보안 체크리스트 (접근통제)

분야	항목 설명		
접근통제	AC-01	접근통제 정책	• 시스템 접근권한을 부여한 기기, 사용자 및 프로세스에 한하여 접근을 허용해야 한다
	AC-02	최소권한	• 사용자에게 부여된 과업 및 직책을 수행하는데 필요한 최소한의 권한을 부여한다.
	AC-03	특수 권한 사용	• 특수권한 사용자가 실행할 수 있는 기능에 대한 시스템 접속을 제한하고 특수권한으로 실행되는 기능들을 감사해야 한다.
	AC-04	정보흐름 통제	• 시스템 내부 및 시스템 간 정보 흐름을 통제해야 한다.
	AC-05	직무 분리	• 개인의 직무를 분리하고 이에 따라 시스템의 접근권한을 부여해야 한다.
	AC-06	로그인 시도 실패	• 일정 기간 동안 연속으로 유효하지 않은 로그인 시도를 제한하고 최대 허용횟수를 초과하면 자동으로 계정을 잠궈야 한다.
	AC-07	세션 잠금 및 종료	• 일정 기간 동안 세션 사용이 없거나 사용자에 의한 세션 잠금 요청이 있을 경우 해당 세션을 잠그고,세션 종료 조건 발생 시 자동으로 세션을 종료해야 한다.
	AC-08	원격 접근통제	• 승인된 업무 및 사용자에 대해서만 원격접속을 허용하고 원격접속 세션을 암호화 및 모니터링해야 한다.

2 CMMC : Cybersecurity Maturity Model Certification
3 K-RMF : Korea - Risk Management Framework
4 NIS : network and information systems
5 ISMS : Information Security Management System

분야	항목 설명		
	AC-09	무선 접속	• 시스템에 무선접속시 승인받은 사용자/기기 인증을 수행하고 통신세션을 암호화해야 한다.
	AC-10	모바일기기 연결 통제	• 승인된 모바일 장치에 대해서만 시스템의 연결을 허용하고 모바일 장치에서 정보를 암호화해야 한다.
	AC-11	외부 연결 통제	• 외부 시스템과 조직 내부시스템에 대한 연결 및 사용을 확인하고 통제해야 한다.
	AC-12	공공 정보 통제	• 공개적으로 접근 가능한 시스템에 정보를 게시하기 전에 해당 내용을 검토하여 중요정보가 게시되지 않도록 한다.
식별 및 인증	IA-01	식별 및 인증	• 시스템 사용자, 프로세스 및 장치를 식별하고 인증해야 한다.
	IA-02	다중 인증	• 특수권한 계정으로 네트워크에 접속할 경우에는 다중 인증을 사용하고 재전송 공격 방지 인증 메커니즘을 적용해야 한다.
시스템 및 통신 보안	SC-01	경계 보호	• 조직 시스템의 외부 경계와 주요 내부 경계에서의 통신(송수신 정보)을 모니터링, 제어 및 보호해야 한다.
	SC-02	보안공학 원칙 적용 및 기능 분리	• 보안 아키텍처는 심층 방어 원칙을 기반으로 설계하고, 시스템의 관리 기능과 사용자 기능을 명확히 분리하여 운영하여야 하며, 시스템 개발 과정에서는 보안공학 원칙을 적용하여야 한다.
	SC-03	저장 및 전송 정보 보안	• 저장 및 전송되는 정보의 기밀성 및 무결성을 보호해야 한다.
	SC-04	통신 보안	• 기본적으로 모든 트래픽을 거부하고, 필요한 트래픽만 예외적으로 허용하는 방식으로 운용하고, 로컬 및 원격연결을 동시에 하지 못하도록 통제하며 통신세션 종료 이후 또는 일정 기간 동안 작업이 없을 경우 통신 세션과 관련된 연결을 종료해야 한다.
	SC-05	암호화	• 중요 정보는 암호화하고 암호화를 위한 암호키를 설정하고 관리해야 한다.
	SC-06	협업 컴퓨팅 장치	• 협업 컴퓨팅 장치의 원격 활성화를 금지하고 장치가 사용 중일 때는 물리적으로 나타나는 표시를 통해 사용자가 장치가 사용 중임을 인식할 수 있어야 한다.
	SC-07	모바일 코드 및 VoIP 통제	• 시스템 내 모바일 코드 및 VoIP의 사용을 모니터링 · 통제 해야 한다.

분야	항목 설명		
시스템 및 정보 무결성	SI-01	취약점 점검 및 결함교정	• 시스템과 애플리케이션의 취약점을 주기적으로 검사하고, 해당 시스템에 영향을 미치는 신규 취약점이 확인될 때마다 검사하여 시스템의 결함을 식별, 조치, 보고해야 한다.
	SI-02	악성코드 방지	• 악성코드 식별 및 제거를 위해 시스템에 악성코드 방지솔루션을 설치하고 파일 다운로드시 실시간으로 검사해야 한다.
	SI-03	보안 경보, 권고	• 시스템 보안 경고와 권고를 모니터링하고 이에 대한 대책을 수립해야 한다.
	SI-04	시스템 및 통신 트래픽 모니터링	• 시스템의 무단 사용을 모니터링하고 송 · 수신되는 네트워크 트래픽을 주기적으로 모니터링해야 한다.
시스템/ 서비스 운영 관리	SO-01	유지보수 통제	• 시스템 유지관리에 사용되는 도구, 기술, 메커니즘 및 인력을 통제해야 한다. - 원격 유지보수 시스템 외부 반출 전 정보소거 - 유지보수용 저장매체 악성코드 검사 - 원격 유지보수 시 사전승인, 강화된 인증, 유지보수 활동 기록, 업무 종료 시 세션 종료 - 유지보수 인력 관리 감독
	SO-02	시스템 감사 및 감사기록 분석, 보고	• 불법적이거나 승인되지 않은 시스템 활동을 모니터링, 분석, 조사 및 보고하기 위한 시스템 감사 로그 및 기록을 생성 및 보관해야 하고 부적절하거나 비정상적 활동을 분석 및 보고해야 한다. 또한 감사 정보를 보호하고 감사 로깅 오류시 경고한다.
	SO-03	시간동기화	• 감사기록을 위한 타임스템프생성을 위해 내부 시스템 (NTP서버) 시간을 사용해야 한다.
	SO-04	휴대용 저장장치 (저장매체 등) 보안	• 중요정보가 저장된 저장매체 및 휴대용 PC는 물리적으로 안전하게 보관하고 기밀성, 무결성을 보호하기 위해 통제해야 한다. - 저장매체 이동시 암호화 등으로 보호 - 폐기 또는 재사용을 위해 반출되기 전에 정보소거하거나파기 - 매체 백업 정보의 기밀성 보호
	SO-05	형상관리	• 시스템 구축 및 운영의 통제기준이 되는 최신화된 형상관리 기준선(Baseline)을 식별하고 시스템 정보기술 제품들의 보안 환경설정을 수립 및 문서화해야 한다.
	SO-06	시스템 및 애플리케이션 보안 요구사항 정의	• 사업 기획 단계에서 시스템 및 서비스에 대한 정보보안 요구사항을 정의해야 하며, 안전한 코딩 방안을 포함하여야 한다.

분야	항목 설명		
	SO-07	시스템/ 애플리케이션 변경관리	• 시스템 및 애플리케이션의 변경 사항을 검토, 승인/거부하고 변경내역을 기록해야 하며 변경 전에 변경에 대한 잠재적인 보안 영향을 분석해야 한다.
	SO-08	개발 시험 및 평가	• 사전 정의된 보안 요구사항에 따라 정보시스템이 도입 또는 구현되었는지를 검토하기 위하여 법적 요구사항 준수, 최신 보안취약점 점검, 안전한 코딩 구현 등의 검토 기준과 절차를 수립·이행하고, 발견된 문제점에 대한 개선조치를 수행하여야 한다.
	SO-09	기능최소화 및 사용자설치 소프트웨어 통제	• 필수 기능만 제공하도록 시스템을 설정하고 사용자가 설치한 소프트웨어를 통제하고 모니터링한다.
사고 대응	IR-01	사고 처리 및 테스트	• 사고대응 준비, 사고 탐지, 사고 조사/분석, 피해 시스템의 분리 및 차단, 피해 시스템 복구를 포함한 사고 처리 대응 체계를 구축하고 주기적으로 사고대응 테스트를 실시해야 한다.
	IR-02	사고 보고	• 사고를 인지한 인원이 지정한 시간 내에 사고대응 부서에 신고하고 사고대응 부서는 사고를 관련 기관에게 통지해야 한다.
인원보안	PS-01	인원보안	• 직원 고용시 배경검사를 시행하고 보직 변경/퇴직시시스템 접근 권한을 검토/변경/삭제해야 하며 기업의 보안 정책 위반시 징계 절차를 수립해야 한다.
	PS-02	보안인식 교육·훈련	• 직무별 전문성을 확보할 수 있도록 인식제고 활동 및 교육훈련 계획을 수립 및 시행해야 한다.
물리보안	PE-01	물리적 접근통제	• 시스템이 설치·운영되고 있는 시설의 출입을 통제하고 모니터링하며 물리적 접근 이력을 주기적으로 검토해야 한다.
	PE-02	대체 근무장소 보안	• 대체 근무장소(재택, 출장지, 원격 사무실 등)에서 중요 정보에 대한 안전조치를 시행한다.
	PE-03	보호설비 운영	• 보호구역에 위치한 정보시스템의 중요도 및 특성에 따라 온도·습도 조절, 화재감지, 소화설비, 누수감지, UPS, 비상발전기, 이중전원선 등의 보호설비를 갖추고 운영절차를 수립·운영하여야 한다.
위험 평가 및 보안평가	RA-01	위험 평가	• 시스템 운영 및 관련 정보의 처리, 저장 또는 전송으로 인해 발생하는 조직 운영(임무, 기능, 이미지 또는 평판 포함), 조직 자산 및 개인에 대한 위험을 주기적으로 평가해야 한다.
	RA-02	보안 통제 모니터링 및 효과성 평가	• 지속적으로 보안 통제를 모니터링하여 보안통제의 지속적인 효과를 보장해야 한다.

분야	항목 설명		
보안 거버넌스	SG-01	보안 정책 수립	• 우주보안 정책 및 지침을 수립하여 경영진의 승인을 받고 주기적으로 검토 및 개정하여야 한다.
	SG-02	보안 역할 및 책임 정의	• 우주보안 관련 책임자 및 담당자의 역할·책임을 정의하고, 조직 변화에 따라 이를 지속적으로 유지·관리해야 한다.
	SG-03	자산관리	• 우주 관련 자산을 식별하고 목록화하며, 변동 사항을 반영하여 최신 상태로 관리해야 한다.
	SG-04	법적요구사항 준수	• 우주보안 관련 법적 요구사항을 주기적으로 파악하여 규정에 반영하고, 준수 여부를 지속적으로 검토하여야 한다.
비상계획	CP-01	비상계획 수립	• 우주 시스템의 운영 연속성을 위협할 수 있는 보안 위협 유형을 식별해야 하며, 비상시 복구 절차, 복구 조직, 비상연락체계 등 비상계획을 수립하고 주기적으로 점검해야 한다.
	CP-02	백업 및 이중화 관리	• 조직의 중요정보를 식별하고 주기적으로 백업하며 중요 네트워크, 시스템은 이중화한다.
공급망 관리	SM-01	공급망 보호	• 협력사로 인해 발생할 수 있는 보안 위협을 방지하기 위해 공급망 보안 정책을 수립하여 협력사 선정을 위한 기준과 계약서를 마련하고, 협력사 명부를 작성 및 최신화해야 한다
	SM-02	인수 전 평가	• 시스템/구성요소/서비스의 선정/인수/ 업데이트 전에 보안취약점 점검 및 조치하고 인수 테스트를 통해 구성요소의 위조를 검사해야 한다.
	SM-03	모든 출처 정보 사용	• 시스템/구성요소/서비스 공급업체를 대상으로 모든 출처 정보 분석을 수행해야 한다.
	SM-04	변조/위조 방지 및 탐지	• 시스템/구성요소/서비스의 변조 및 위조를 방지하기 위하여 주기적으로 점검해야 한다.

우주 보안모델 요약본

인 쇄 | 2025 년 12 월
발 행 | 2025 년 12 월

발행처 | 한국인터넷진흥원
(58324) 전라남도 나주시 진흥길 9